

AVE AFRICA INSURANCE CLAIMS MANAGEMENT PLATFORM

API Architecture Document

Technical Reference · v1.0

Framework	Node.js / Express 4.x
Auth	JWT RS512 + API Key (SHA-256)
Transport	HTTP REST + WebSocket (Socket.IO)
Database	MongoDB via Mongoose 8.x



Table of Contents

1.	High-Level Architecture	3
2.	Authentication Architecture	4
3.	Request Lifecycle — Middleware Pipeline	5
4.	Route Groups Overview	6
5.	Provider Portal Routes	7
6.	Company API & Claims Routes	8
7.	Actor Routes (Assessor, Garage, Supplier, Customer)	9
8.	Supporting Routes	10
9.	Service Layer	11
10.	Middleware Reference	12
11.	Real-Time Events (Socket.IO)	12
12.	Security Architecture	13
13.	Environment Variables	14

1. High-Level Architecture

The platform consists of layered components. Clients communicate exclusively through the Express HTTP server.



2. Authentication Architecture

Three parallel authentication paths serve different client types. All JWT tokens are signed RS512 using a private/public keypair.



3. Request Lifecycle — Middleware Pipeline

Every incoming HTTP request passes through these stages in order. The `catchAsync` wrapper catches thrown errors and routes them to the global error handler.



4. Route Groups Overview

/provider/* Auth: verifyProviderToken	/companies /plans /subscriptions /invoices /api-keys /support /dashboard /audit-logs /demo-requests
/api/v1/* Auth: verifyApiKey	/company /subscriptions /invoices /me
/support Auth: verifyToken	Support ticket CRUD + messaging for company users
/claims/* Auth: verifyToken	Create Approve Reject Award Bid AssessorReport GarageCompletion SupplierBid ClaimLink
/customers/* Auth: verifyToken / Public	Register Login Profile Claims Garages
/assessors/* Auth: verifyToken / Public	Create Login Bids Report CompleteJob TopAssessors
/garages/* Auth: verifyToken / Public	Create Login Bids CompleteJob TopGarages AssessedClaims
/suppliers/* Auth: verifyToken / Public	Create Login SupplyBid PartsDelivered ClaimsInGarage
/users/* Auth: verifyToken / Public	Create Login CompanyUsers Update ResetPassword
/rating /roles /notification / /audit Auth: Varies	Ratings RBAC Roles Notifications S3 Uploads Audit Logs

5. Provider Portal Routes

5.1 Provider Users (verifyProviderToken)

Method	Endpoint	Auth	Purpose
POST	/provider/login	Public	Provider staff login
GET	/provider/users	verifyProviderToken	List all provider users
POST	/provider/users	verifyProviderToken	Create provider user
GET	/provider/users/:id	verifyProviderToken	Get provider user by ID
PATCH	/provider/users/:id	verifyProviderToken	Update provider user
PATCH	/provider/users/:id/deactivate	verifyProviderToken	Deactivate provider user

5.2 Insurance Company Management

Method	Endpoint	Auth	Purpose
POST	/provider/companies/login	Public	Company login
POST	/provider/companies/reset-password	Public	Reset company password
POST	/provider/companies	verifyProviderToken	Onboard new company
GET	/provider/companies	verifyProviderToken	List all companies
GET	/provider/companies/:id	verifyProviderToken	Get company details
PATCH	/provider/companies/:id	verifyProviderToken	Update company profile
PATCH	/provider/companies/:id/status	verifyProviderToken	Change company status
DELETE	/provider/companies/:id	verifyProviderToken	Delete company
GET	/provider/companies/:id/stats	verifyProviderToken	Company statistics

5.3 Plans, Subscriptions & Invoices

Method	Endpoint	Auth	Purpose
GET	/provider/plans	Public	List subscription plans
POST	/provider/plans	verifyProviderToken	Create plan
PATCH	/provider/plans/:id	verifyProviderToken	Update plan
PATCH	/provider/plans/:id/toggle	verifyProviderToken	Enable or disable plan
POST	/provider/subscriptions	verifyProviderToken	Assign subscription to company
GET	/provider/subscriptions	verifyProviderToken	List all subscriptions
PATCH	/provider/subscriptions/:id/cancel	verifyProviderToken	Cancel subscription
POST	/provider/invoices	verifyProviderToken	Create invoice
GET	/provider/invoices	verifyProviderToken	List all invoices
PATCH	/provider/invoices/:id/pay	verifyProviderToken	Mark invoice as paid

6. Company API & Claims Routes

6.1 Company Self-Service API (/api/v1/*) — verifyApiKey

Method	Endpoint	Auth	Purpose
GET	/api/v1/company	verifyApiKey	Fetch own company profile
GET	/api/v1/subscriptions	verifyApiKey	List company subscriptions
GET	/api/v1/subscriptions/active	verifyApiKey	Get active subscription
GET	/api/v1/invoices	verifyApiKey	List invoices (paginated)
GET	/api/v1/me	verifyApiKey	Get current API key metadata

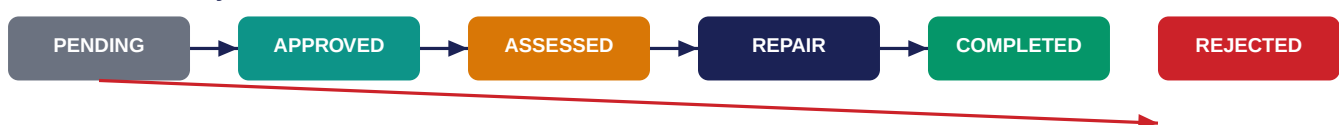
6.2 Support Tickets (/support/*) — verifyToken

Method	Endpoint	Auth	Purpose
POST	/support	verifyToken	Open new support ticket
GET	/support	verifyToken	List own tickets (paginated)
GET	/support/:id	verifyToken	View ticket and message thread
POST	/support/:id/message	verifyToken	Reply to support ticket

6.3 Claims Workflow (/claims/*) — verifyToken

Method	Endpoint	Auth	Purpose
POST	/claims/create	verifyToken	Create new claim
GET	/claims	verifyToken	List all claims
GET	/claims/count	verifyToken	Count claims by status
GET	/claims/:id	verifyToken	Get claim details
PATCH	/claims/:id	verifyToken	Update claim
PATCH	/claims/approve/:id	verifyToken	Approve claim
PATCH	/claims/reject/:id	verifyToken	Reject claim with reason
POST	/claims/generate-claim-link	verifyToken	Generate shareable claim link
POST	/claims/file-claim/:token	verifyToken	File claim via one-time token
GET	/claims/bids/:id	verifyToken	Get all bids on a claim
POST	/claims/awardClaim/:id	verifyToken	Award claim to assessor
POST	/claims/awardGarage/:id	verifyToken	Award repair to garage
POST	/claims/rejectAssessorBid/:id	verifyToken	Reject assessor bid
POST	/claims/rejectGarageBid/:id	verifyToken	Reject garage bid
GET	/claims/assessed	verifyToken	Get assessed claims for repair
GET	/claims/supplier-bids/:claimId	verifyToken	Get supplier bids for claim
POST	/claims/awardSupplier/:claimId/:bidId	verifyToken	Award to supplier

Claim Status Lifecycle



7. Actor Routes

7.1 Assessors (/assessors/*)

Method	Endpoint	Auth	Purpose
POST	/assessors/login	Public	Assessor login
POST	/assessors/create	verifyToken	Create assessor account
GET	/assessors	verifyToken	List all assessors
GET	/assessors/topAssessors	verifyToken	Get top-rated assessors
GET	/assessors/:id	verifyToken	Get assessor by ID
PUT	/assessors/:id	verifyToken	Update assessor profile
GET	/assessors/myBids/:assessorId	verifyToken	Get assessor bid history
POST	/assessors/bid/:claimId	verifyToken	Place bid on claim
POST	/assessors/submitReport/:claimId	verifyToken	Submit assessment report
POST	/assessors/completeJob/:id	verifyToken	Mark reassessment complete

7.2 Garages (/garages/*)

Method	Endpoint	Auth	Purpose
POST	/garages/login	Public	Garage login
POST	/garages/create	verifyToken	Create garage account
GET	/garages	verifyToken	List all garages
GET	/garages/topGarages	verifyToken	Get top-rated garages
GET	/garages/assessedClaims/:garageId	verifyToken	Get assessed claims
GET	/garages/myBids/:garageId	verifyToken	Get garage bid history
POST	/garages/bidClaim/:id	verifyToken	Place bid on claim
POST	/garages/completeJob/:id	verifyToken	Mark repair complete

7.3 Suppliers (/suppliers/*)

Method	Endpoint	Auth	Purpose
POST	/suppliers/create	Public	Create supplier account
POST	/suppliers/login	Public	Supplier login
GET	/suppliers	verifyToken	List all suppliers
GET	/suppliers/claimsInGarage	verifyToken	Get claims currently in garage
GET	/suppliers/myBids/:supplierId	verifyToken	Get bid history
POST	/suppliers/supplyBid/:claimId	verifyToken	Submit supply bid
POST	/suppliers/partsDelivered/:claimId	verifyToken	Mark parts delivered

7.4 Customers (/customers/*)

Method	Endpoint	Auth	Purpose
POST	/customers/register	Public	Register new customer
POST	/customers/login	Public	Customer login
GET	/customers	verifyToken	List all customers
PUT	/customers/updateCustomer/:customerId	verifyToken	Update customer profile
GET	/customers/myClaims/:customerId	verifyToken	Get customer claims
GET	/customers/get-garages/:claimId	verifyToken	Get garages for a claim

8. Supporting Routes

8.1 Ratings, Roles, Notifications, Uploads, Audit

Method	Endpoint	Auth	Purpose
POST	/rating/:entityType/:entityId	verifyToken	Submit rating for entity
GET	/rating/:entityType/:entityId	verifyToken	Get ratings for entity
POST	/roles	Public	Create role
GET	/roles	Public	List all roles
PUT	/roles/:id	Public	Update role
DELETE	/roles/:id	Public	Delete role
POST	/images/upload	Multer	Upload image to AWS S3
POST	/notification	Public	Create notification
GET	/notification	Public	List notifications
PUT	/notification/notifications/:id	Public	Mark notification as read
GET	/audit/audit-logs	Public	Retrieve audit logs

9. Service Layer

21 service modules encapsulate all business logic. Controllers are thin orchestrators; services own domain rules.

auth.service.js
User authentication and session management

claim.service.js
Full claim lifecycle (create, approve, award, complete)

insuranceCompany.service.js
Company onboarding and profile management

invoice.service.js
Invoice generation and status tracking

supportTicket.service.js
Support ticket CRUD and message threading

providerDashboard.service.js
Analytics aggregations for provider dashboard

garage.service.js
Garage profile and bid operations

customerService.js
Customer account operations

rating.service.js
Rating submission and aggregation

demoRequest.service.js
Demo request CRUD

audit.service.js
Audit log writes (simple model)

token.service.js
JWT generation, verification, and blacklisting

apiKey.service.js
API key generation, validation, and revocation

companySubscription.service.js
Company subscription lifecycle (assign, renew, cancel)

subscriptionPlan.service.js
Subscription plan template CRUD

providerAuditLog.service.js
Provider action audit log writes and queries

assessor.service.js
Assessor profile and bid operations

supplier.service.js
Supplier profile and supply bid operations

users.service.js
Company staff user management

roles.service.js
Role and permission CRUD

email.service.js
Email dispatch via Nodemailer

10. Middleware Reference

Middleware	Applied To	Purpose
<code>express.json()</code>	All routes	Parse JSON request bodies
<code>cors()</code>	All routes	Allow cross-origin requests (origin: *)
<code>verifyToken</code>	Company / customer routes	Validate RS512 JWT, attach req.user
<code>verifyProviderToken</code>	Provider routes	Validate RS512 JWT, reject non-ProviderUser accounts
<code>verifyApiKey</code>	/api/v1/* routes	Validate SHA-256 API key hash, check permissions
<code>providerAuditLogger</code>	All /provider/* routes	Auto-log every action to ProviderAuditLog
<code>multer</code>	/images/upload	Handle multipart file uploads to S3

verifyApiKey — Detailed Flow

1	Extract	Raw key from x-api-key header or Authorization: ApiKey <key>
2	Hash	Compute SHA-256 hash of the raw key
3	Lookup	Match keyHash in ApiKey collection (unique index, sub-ms)
4	Validate	Check key status=active, not expired
5	Company check	Verify InsuranceCompany status is not suspended
6	Permissions	If required, validate key.permissions against required set
7	Attach	Set req.apiKey and req.company for downstream controllers

11. Real-Time Events (Socket.IO)

Event	Direction	Purpose
<code>custom-event</code>	Client to Server	General purpose event trigger
<code>response-event</code>	Server to Client	General purpose response
<code>connection</code>	System	Client connected notification
<code>disconnect</code>	System	Client disconnected notification

Socket.IO Configuration

Transport: WebSocket with HTTP long-poll fallback
 CORS origins: *, https://admin.aveafricasolutions.com/
 Allowed methods: GET, POST, PUT, DELETE

12. Security Architecture

PH

Password Hashing

bcrypt rounds=10 on all user-type collections (Users, Assessor, Garage, Supplier, Customer, InsuranceCompany, ProviderUser)

JW

JWT Signing

RS512 asymmetric keypair. private.pem signs tokens. public.pem verifies. Compromising the public key does not allow token forgery.

AK

API Key Storage

Only SHA-256 hash stored. Raw key shown once on generation, never persisted. Hash is indexed for sub-millisecond lookup.

TR

Token Revocation

Blacklist in Token collection. TTL index auto-expires tokens at their expiry date. No cron job required.

AT

Audit Trail

Every provider action logged with timestamp, IP, user-agent, redacted body, HTTP method, endpoint, outcome, and latency.

SR

Sensitive Field Redaction

Audit logger strips: password, keyHash, rawKey, secret, token, accessToken, refreshToken, privateKey, apiKey from request body before writing.

12.1 Known Hardening Recommendations

Severity	Issue	Area	Recommendation
MEDIUM	CORS origin is wildcard (*)	Config	Restrict to known frontend domains in production
MEDIUM	Role routes are unprotected	Routes	Add verifyToken or verifyProviderToken to role management
MEDIUM	Notification routes are unprotected	Routes	Add authentication to notification endpoints
MEDIUM	Audit route is unprotected	Routes	Restrict /audit/audit-logs to authenticated users only

13. Environment Variables

Variable	Purpose
MONGO_URI	MongoDB connection string
PORT	Server port (default: 3000)
JWT_KEY	Symmetric JWT secret (legacy; RS512 keys take precedence)
JWT_ACCESS_EXPIRATION_MINUTES	Access token lifetime in minutes
JWT_REFRESH_EXPIRATION_HOURS	Refresh token lifetime in hours
AWS_ACCESS_KEY_ID	AWS S3 access key
AWS_SECRET_ACCESS_KEY	AWS S3 secret
AWS_REGION	AWS region
AWS_S3_BUCKET	S3 bucket name
SMTP_HOST	Nodemailer SMTP host
SMTP_PORT	Nodemailer SMTP port
SMTP_USER	Nodemailer SMTP user
SMTP_PASS	Nodemailer SMTP password

Utility Modules

 ApiError.js	Custom error class with HTTP statusCode and isOperational flag
 catchAsync.js	Wraps async handlers; rolls back MongoDB session on error
 encryption.js	AES-256-GCM field-level encryption and decryption
 upload.js	Multer configuration for memory storage and S3 streaming
 transaction.js	MongoDB session management (start, commit, rollback)
 auditHelper.js	Structured audit log builder with sensitive field redaction
 generateInvoicePdf.js	PDFKit invoice renderer (A4 branded layout)

AVE Africa Insurance Claims Management Platform

API Architecture Document · Version 1.0 · Prepared by Neurodev Technologies · Confidential

This document describes the REST API architecture of the AVE Africa platform. All route structures, middleware behaviour, and security controls described herein are subject to change as the platform evolves.